

```
<h1 v-bind:title="userProvidedString">
  hello
</h1>
```

if `userProvidedString` contained:

```
'" onclick="alert(\'hi\')'
```

then it would be escaped to the following HTML:

```
&quot; onclick=&quot;alert('hi')
```

HTML template

Copyright Attribution: vue.js

some degree, sandboxed within iframes. When a critical function necessitates any degree of vulnerability, it is up to the team to weigh the value of the feature against the worst-case scenarios enabled by the vulnerability.

Injecting HTML

Vue, as you already know, immediately escapes HTML text, stopping you from inadvertently inserting executable HTML into your program. However, if you are certain that the HTML is secure, you may directly make HTML content:

It is important to note that user-provided HTML is never really secure unless it is in a sandboxed iframe or in a section of the app where only the user who wrote the HTML will ever be exposed to it. Allowing users to build their own Vue models poses comparable risks.

Injecting URLs

In a URL like

```
<a v-bind:href="userProvidedUrl">
  click me
</a>
```

When the URL has not been “sanitized” to block JavaScript execution